CyBOK

Forensics and Cybercrime Research and State of the Art

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

This lecture

- This lecture will focus on current challenges and what the research has to offer
- With a continuously developing area, new things are happening all the time
- The idea here is to discuss some of the current trends related to incident management and response

Litterature note

- The purpose of this lecture is to bring attention to some RnD areas

- The lecture is primarily built on the following publications:
  - Kävrestad, J., Zaxmy, J., & Nohlberg, M. (2020). Analyzing the usage of character groups and keyboard patterns in password creation. *Information & Computer Security*, *28*(3), 347-358.
  - Kävrestad, J., Lennartsson, M., Birath, M., & Nohlberg, M. (2020). Constructing secure and memorable passwords. *Information & Computer Security*, *28*(5), 701-717.
  - Lindqvist, G., & Kävrestad, J. (2023). How privacy concerns impact Swedish citizens' willingness to report crimes: a quantitative mobile phone survey. *Information & Computer Security*.

Litterature note

- The lecture is primarily built on the following publications (cont):
  - Alshumrani, A., Clarke, N., & Ghita, B. (2023, February). A Unified Forensics Analysis Approach to Digital Investigation. Academic Conferences International Ltd.
  - Al Fahdi, M., Clarke, N. L., Li, F., & Furnell, S. M. (2016). A suspect-oriented intelligent and automated computer forensic analysis. *Digital Investigation*, *18*, 65-76.

Agenda

- Password cracking!
- Privacy in evidence processing
- Data volumes
- Unified forensic analysis

Authentication recap

CyBOK

- First line in ensuring Confidentiality, Availability and Integrity of data in a computer system is authentication.

- Authentication is the process of proving your identity to the system and sometimes vice versa
  - i.e logging in

- Authentication is traditionally done with passwords but other mechanisms such as biometrics, tokens and combinations are common in moderns systems.

Authentication recap

CyBOK

- To make authentication work, passwords need to be stored on the computer that a user wants to log on to
  - Big issue!!

- Instead of storing passwords in plain text, most computers stores a password hash – that is a password that has been ran through a hashing algorithm.

- Upon logging on to the computer, the user-submitted password is hashed and the hash is compared to the stored password hash.

Authentication recap

- Hashing is basically a one-way function that takes some data as input(P) and produces a hash-value, or digest(H).
  - P → H

- The hash function is one-way to its nature, meaning that you cant derive P from H

- The function is also consistent meaning that Px will always generate the same Hx

Encryption recap

- Most computers are somewhat secure, by using authentication, when they run.
- However, someone may lift out the hard drive and read the data – it is commonly in plain text.
- One way to make data secure to such actions is to encrypt it – thus making it unreadable without the correct password.

Encryption recap

- Encryption is the process of taking some plain text data (P) and a key (K) and produce a ciphertext (C)
  - P + K = C

- In contrast to hashing, encryption is reversible for anyone who has the key – having C and K, you can get P
  - C + K = P

- Divided into symmetric encryption (same key for encryption and decryption as above) and asymmetric encryption (using a key-pair)

Encryption recap

- To use asymmetric encryption you create a key pair with a public (K1) and a private (K2) key.

- K1 is used for encryption and can be sent out to anyone:
  - P + K1 = C

- K2 is used for decryption and is kept safe
  - C + K2 = P

- It is not possible to use K1 to decrypt data encrypted with K1

Encryption recap

- Symmetric encryption algorithms are fast and quite secure, however they introduce tedious key-management issues.
  - Key must sent in a secure manner to the recipient.
  - If you can securely share the key, why don't you just share the data in that way?
  - Neat for drive encryption – no one but you needs the key!

- Asymmetric encryption does not suffer from key-exchange problems but is slower, usually to slow for big data-sets and time –sensitive applications.

- Common solution: use asymmetric encryption to share symetric keys. Then use symmetric encryption for communication.

Encryption recap

- In encryption the key is usually derived from a password using a password expanding algorithm. The key must be big enough so that a key-space attack is not possible

- Also, decryption with the wrong K must not reveal anything about the plain text. Thus, using the wrong key will result in bottom, a mathematic constant.

- Finally, the algorithm must be securely implemented to avoid decryption attacks.

Encryption recap

- For a hash algorithm to be seen as secure, it must meet two requirements.

- **Collision resistant** meaning that there is only one possible digest for every input data set

- **Irreversible** meaning that there is no way to transform the digest into the plain text.

Encryption recap

- In cryptography you discuss algorithms as secure or computationally secure.
- Secure means that they fully meet the security requirements
- Computationally secure means that they may not completely meet the security requirements, but its not reasonable to break them.
  - You can in theory break SHA-256 – but it is not feasible
- Yes, computationally secure becomes context-based

REFLECT!

- Use one minute to write down one-liners that reflect what you learned so far.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Cracking

- With that background – lets go into the cracking.

- We will explore several ways of cracking passwords and encryption:
  - Decryption
  - Key-space
  - Brute force
  - Dictionary
  - Social hacking

Cracking - decryption

CyBOK

- A decryption attack is basically exploiting a poor implementation of an encryption or hashing algorithm
- Instead of trying to decrypt the plaintext you look into how the implementation is designed and look for weaknesses.
- A well known bad crypto-implementation was the WEP protocol for wireless security
- A service that i broke when working with the police was called privnote.
- Remember that programs are written by humans, and we are seldom perfect!

Cracking – key-space

- Some algorithms provide a way to small key space. This makes it possible to just ignore the password and go right to exhausting the key space by testing every possible binary key.

- A hash susceptible to this attack does not meet the collision resistance criteria. Instead, several P produce the same H – consider the consequences.

- This attack is often seen as obsolete. But as we get more computer power the requirements for an algorithm to be computationally secure increases.

Cracking – brute force

- Same as a key-space attack but attacks the password instead of the key-space.
- In this attack you would test every possible password until you find the correct one.
- The success factor becomes the password length and the types of signs that are available.
- Longer password and more available signs = more possible passwords (bigger password space).

Cracking – brute force

- To know if a brute force attack is feasible you need to calculate the password space:
  - the number of different signs to the power of *n* were *n* is the password length.
- Know how many passwords you can test in a period of time, like a day:
  - 10 billion tests in 24 hours is quite reasonable
- Finally, on average, we will have to test 50% of the possible passwords leading to the following formula:
- (password space / attempts per day)/2 = average cracking time in days.

Cracking – brute force

Password length	Equation	Resulting password space	Sample crack time in days
2	62^2	3844	0,0000002
4	62^4	14776336	0,00074
5	62^5	916132832	0,046
6	62^6	56800235584	2,85
7	62^7	3521614606208	176
8	62^8	218340105584896	10917

The attacks so far

- The attacks presented so far can work good if someone has made a mistake or the algorithm is obsolete.
- Bad implementation allows encryption attack
- Small key-space allows key space attack
- Short passwords allows brute force attacks
- But if these flaws are not present, we need to exploit human nature!

Human nature

- Users are not security experts – and it would be stupid to expect them to be.

- Second – cognitive functions make it near damn impossible for us all to follow password guidelines.

- We are often asked to make looooong and complex passwords, but can only remember ~8 random characters
  - PROBLEM!

Human nature

CyBOK

- This brings out our lesson: if a hacker learns and predicts how humans behave, act and react she can hack a computer system without even touching technology.
- If too complex passwords are forced on us, we write them down.
- If too long passwords are forced on us we use predictable memory strategies
- If someone we dont know calls us and asks for our passwords we do what?

Dictionary attack

- When we want to crack passwords we can exploit the fact that people tend to create passwords they can remember and use the same password for several accounts.
- Using this knowledge we can use a more sophisticated approach than to exhaust the password space; namely a dictionary attack.
- A dictionary attack is similar to a brute-force, but instead of testing all possibilities you create a list of somewhat likely passwords and try them
- Can be seen as doing somewhat educated guesses, and remember, we can do 10 billion guesses in 24 hours.

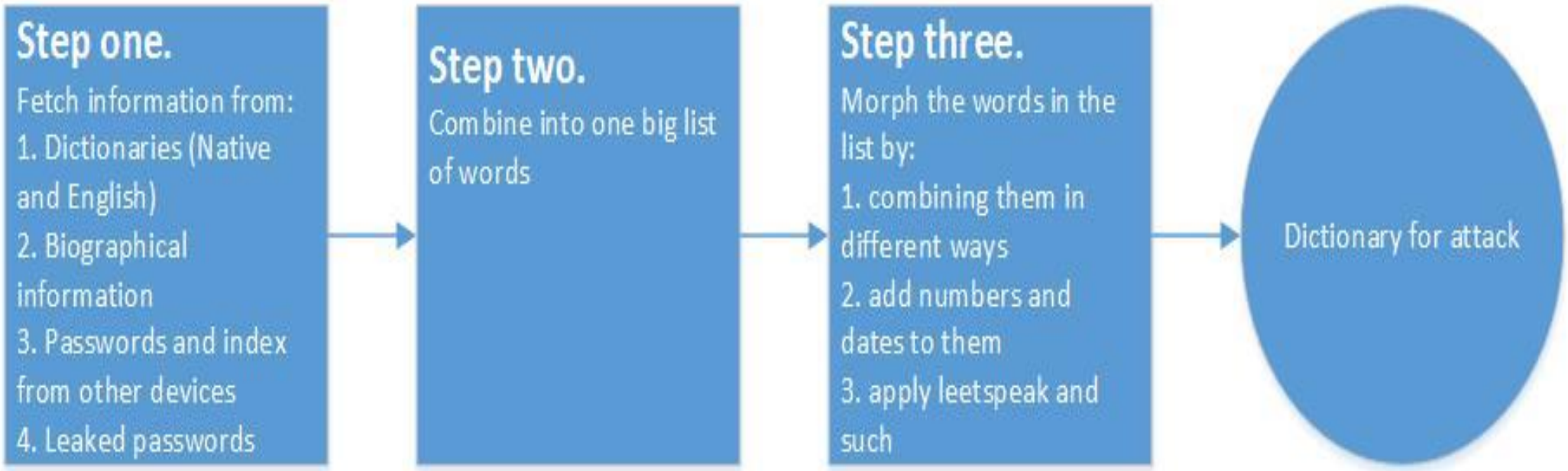
Dictionary attack

- Ground rules are simple. If the password you need to crack is in your dictionary – the password will be cracked. The trick is to be good at building dictionaries.

- People tend to build passwords:
  - With words
  - With patterns
  - Relating to stuff they like

- We get that data, scramble it a bit and that is it

Dictionary attack



Dictionary attack

- The result is a list that will crack any password that is made up from:
  - Common words
  - Something relating to interests of the one we attack
  - Something relating to the family of the one we attack
  - Something relating to the one we attack
  - Passwords contained in leaked databases
    - Facebook
    - Linkedin
    - PSN
    - Badoo
    - …..

REFLECT!

- Use one minute to write down one-liners that reflect what you learned so far.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Privacy

- Privacy in forensic examinations is…..troublesome
  - Meant to analyze personal data
- When we investigate suspect devices, we motivate the intrusion with the need to investigate
- And we do the same investigating devices from victims and witnesses
-

Privacy

- Lindqvist and Kävrestad (2023) describe that crime investigation is dependant on victims voluntary participation
  - For reporting
  - For analysis of devices

- They argued that privacy concerns may hinder crimes from being reported if victims are required to submit devices for examination

- They report that victims may be reluctant to submit mobile phones for forensic analysis, but couldn’t identify privacy concerns as the cause

Data volumes

- Todays forensic examinations often involve a lot of data which is a problem for forensic examiners who should find the evidence
  - Often several terabytes per case
  - Many labs face backlogs
- Many different tools with various degree of automation
- Still, lot of manual work is required to analyze all available data

Data volumes

- Gold-standard forensic examinations
  - Leave no stone unturned

- Intelligence-based
  - A subset of data is analyzed depending on information provided to the examiner
  - The idea is to find the relevant information in a timely manner
  - AI can, to some extent help the process

Unified Forensics Analysis

CyBOK

- The data is not only in plentiful supply, it is also often complex
  - Many different types
  - Scattered over different sites
  - Interdependent
- Data complexity leads to a noof for effective data correlation
- Alshumrani et al (2023) suggest that such correlation is not supported by todays tools

Unified Forensics Analysis

CyBOK

- Alshumrani et al (2023) suggest that a unified forensics analysis tool is needed to comply with the complexity challenges

- Such a tool should
  - Integrate and unify multiple data sources
  - Provide an intelligent query feature
  - Understand, correlate, and visualize data

- To do that, it is suggested that a common information exchange language is needed

Thank you for today!